

Wahyudi

Software Engineer · SDET · Application Security · Security Researcher

hi@wahyudi.dev · wahyudi.dev · github.com/halowahyudi · hackerone.com/wint3rcold

SUMMARY

Security-minded software engineer who builds reliable, testable software and then attacks it before adversaries do. I work across the full lifecycle — full-stack product engineering, test automation, application security and offensive research — with a bias toward reproducible, business-impact-focused findings and coordinated disclosure.

EXPERIENCE

Security Researcher — Bug bounty programs · HackerOne Ongoing

- Report multi-program web, API and mobile vulnerabilities, validated and scoped before disclosure.
- Produced reproducible, business-impact-focused reports; findings include authentication bypass, broken access control, SSRF and OAuth/token weaknesses.

Application Security — Freelance Ongoing

- Threat modeling and secure code review across web and API codebases.
- Hardening, patching and CVE triage; translate findings into concrete remediation.

SDET / Quality Engineer — Freelance Ongoing

- Build API and end-to-end test automation at scale; replace fragile manual checks with deterministic suites.
- Embed shift-left testing and quality gates inside CI/CD pipelines.

Software Engineer — Freelance Ongoing

- Ship full-stack web applications with security as a default, not a phase.
- Own delivery end to end: architecture, implementation, testing and hardening.

SELECTED DISCLOSURES

HIGH **Kaltura** — Email verification bypass in self-serve signup allowing unlimited unverified account provisioning.

MEDIUM **Vercel** — OAuth token introspection endpoint returning full token claims without caller authentication.

MEDIUM **OPPO** — Verification ticket delivered to an attacker page via unvalidated MessagePort adoption.

MEDIUM **NBA** — Client-controlled subscription and billing identity fields on a profile update endpoint.

PROJECTS

Gembok — encrypted password manager & authenticator gembok.dev

Zero-knowledge Android vault for passwords, cards and TOTP 2FA codes — encrypted on-device before sync, with no server-side key.

Kotlin · Jetpack Compose · AndroidX Biometric · Room · TOTP

Spotify API Scraper — metadata scraper github.com/halowahyudi/spotify-api-scraper

Lightweight Spotify metadata scraper powering music-discovery experiments without heavy SDK overhead.

Node.js · TypeScript · Puppeteer

SKILLS

Engineering: TypeScript, Next.js, NestJS, Laravel, Tailwind CSS, Firebase, MongoDB, MariaDB, PostgreSQL

Offensive: Burp Suite, Nuclei, ffuf, sqlmap, Metasploit, impacket, hashcat, Nmap

SDET: API & E2E automation, CI/CD quality gates, shift-left testing

AppSec: Threat modeling, secure code review, OWASP Top 10, API security, SDL

Recon / OSINT: subfinder, amass, theHarvester, gobuster, Shodan, Censys

Full methodology, writeups and disclosures at wahyudi.dev — available for security consulting and collaboration.